Cloud Networking

Appunti - Understanding Cloud Security

Basato sul PDF: 05 - CN - Understanding Cloud Security and Cybersecurity

Universita degli Studi di Cagliari - Virginia Pilloni

Voce	Contenuto
Obiettivo	Capire i principi della sicurezza cloud e riconoscere le principali minacce cyber.
Idea chiave	Nel cloud la sicurezza riguarda dati, accessi, comunicazioni, responsabilita condivise e superfici di attacco.
Concetti base	Confidentiality, Integrity, Availability, Authenticity, risk, vulnerability, exploit, threat agent, attack vector, attack surface.
Per l'esame	Saper definire i termini e collegare ogni attacco alla proprieta di sicurezza compromessa.

Indice sintetico

- 1. Information Security
- 2. Confidentiality, Integrity, Availability e Authenticity
- 3. Rischi, vulnerabilita e terminologia cyber
- 4. Common Threats nel cloud
- 5. Malware, botnet e insider threat
- 6. Attacchi applicativi e avanzati
- 7. Tabelle di confronto
- 8. Glossario essenziale
- 9. Domande d'esame con risposta sotto ogni domanda

1. Information Security

La information security e l'insieme coordinato di tecniche, tecnologie, regole e comportamenti che proteggono sistemi informatici e dati. Non e solo un problema tecnico: comprende anche policy, procedure, formazione degli utenti e gestione degli errori umani.

Le misure di sicurezza difendono sia da minacce intenzionalmente malevole sia da errori involontari. Nel cloud questo e piu delicato perche dati, applicazioni e infrastrutture possono trovarsi in ambienti condivisi e parzialmente gestiti da un provider esterno.

Da ricordare
La sicurezza cloud non elimina la responsabilita del consumer. Anche se il provider gestisce l'infrastruttura fisica, il consumer resta responsabile di dati, configurazioni, identita e accessi.

2. CIA + Authenticity

Le proprieta fondamentali sono Confidentiality, Integrity e Availability, cioe la triade CIA. Le slide aggiungono anche Authenticity, collegata alla verifica dell'origine e alla non-repudiation.

Proprieta	Domanda da porsi	Significato nel cloud	Esempio
Confidentiality	Chi puo leggere il dato?	Dati in transito e dati memorizzati devono essere accessibili solo a soggetti autorizzati.	Un messaggio e confidenziale se non viene letto da soggetti non autorizzati.
Integrity	Il dato e rimasto corretto?	Dati trasmessi, salvati, processati e recuperati non devono essere alterati senza autorizzazione.	Il messaggio ricevuto dal servizio cloud deve coincidere con quello inviato.
Availability	Il servizio e raggiungibile?	Risorse e servizi devono essere accessibili e utilizzabili nel periodo richiesto.	Database cloud disponibile durante l'intervallo previsto.
Authenticity	La fonte e davvero quella dichiarata?	Origine di dati, messaggi o interazioni deve essere autorizzata e verificabile.	Firma digitale o log verificabile che collega l'azione a una identita.

2.1 Confidentiality

La confidentiality indica che qualcosa e accessibile solo a parti autorizzate. Nel cloud riguarda soprattutto la protezione del dato durante la trasmissione e quando e memorizzato.

2.2 Integrity

La integrity indica che il dato non e stato alterato da parti non autorizzate. Si applica al trasferimento, allo storage, al processing e al retrieval dei dati.

2.3 Availability

La availability indica che un servizio o una risorsa e accessibile e utilizzabile in uno specifico periodo. Nel cloud puo essere una responsabilita condivisa tra provider, carrier e consumer.

2.4 Authenticity e non-repudiation

La authenticity indica che qualcosa proviene da una sorgente autorizzata. Include la non-repudiation: se una interazione e verificata e registrata, la parte coinvolta non puo negarla dopo.

Errore da evitare
Confidentiality non e authentication. La prima riguarda chi puo leggere il dato; la seconda riguarda la verifica dell'identita o della sorgente.

3. Rischi, vulnerabilita e terminologia cyber

Per analizzare la sicurezza cloud bisogna distinguere bene rischio, vulnerabilita, exploit, minaccia e attacco. Sono concetti collegati ma non equivalenti.

Termine	Definizione semplice	Esempio
Risk	Potenziale perdita indesiderata e inattesa.	Rischio di lettura non autorizzata se il traffico non e cifrato.
Security breach	Incidente che puo causare accesso non autorizzato a sistemi o informazioni.	Un attaccante supera i controlli e accede a un server.
Data breach	Security breach con furto di informazioni confidenziali.	Furto di credenziali o dati sanitari.
Data leak	Condivisione di informazioni sensibili senza necessariamente un attacco.	File riservato inviato al destinatario sbagliato.
Vulnerability	Debolezza fisica, digitale, procedurale o di policy.	Password debole, software non aggiornato.
Exploit	Sfruttamento concreto di una vulnerabilita.	Uso di una falla per ottenere accesso.
Zero-day vulnerability	Vulnerabilita sconosciuta o non ancora corretta.	Falla senza patch disponibile.
Threat	Vulnerabilita nota che pone un rischio.	Phishing verso gli account aziendali.
Threat agent	Entita capace di realizzare un attacco.	Cyber criminale, utente malevolo, APT group.
Attack vector	Percorso usato per attaccare.	Allegato email, pop-up, chat, messaggio istantaneo.
Attack surface	Insieme dei vettori disponibili.	API, porte, account, interfacce e servizi esposti.

Catena logica
Una vulnerabilita aumenta il rischio. Un threat agent usa un attack vector per lanciare un attack. Quando l'attacco sfrutta la vulnerabilita si parla di exploit.

Tipo di attaccante	Obiettivo tipico
Cyber criminals	Rubare informazioni private per profitto o altre attivita illegali.
Malicious users	Utenti autorizzati che abusano dei privilegi per danneggiare o svolgere azioni non autorizzate.
Cyber activists	Promuovere agenda politica, religiosa o sociale con azioni malevole.
State-sponsored attackers	Attaccanti assoldati o supportati da agenzie governative.

4. Common Threats nel cloud

Per ogni minaccia devi saper spiegare che cosa succede, quale proprieta di sicurezza viene colpita e perche il cloud rende quella minaccia importante.

Minaccia	Che cosa succede	Proprieta colpita	Perche conta
Traffic eavesdropping	Intercettazione passiva del traffico.	Confidentiality	Puo restare nascosto perche non altera il traffico.
Malicious intermediary	Intercetta e modifica messaggi.	Confidentiality, Integrity	Puo inserire dati dannosi prima dell'inoltro.
DoS/DDoS	Sovraccarico di risorse, rete o servizi.	Availability	Produce degradazione o fallimento del servizio.
Insufficient authorization	Accesso concesso per errore o troppo ampio.	Confidentiality, Integrity	L'attaccante raggiunge risorse protette.
Weak authentication	Password deboli o account condivisi.	Authenticity, Confidentiality	L'attaccante puo impersonare un utente.
Virtualization attack	Sfrutta vulnerabilita nella virtualizzazione.	CIA	Rischio legato ad accessi amministrativi su risorse virtuali.
Overlapping trust boundaries	Consumer malevolo attacca risorse condivise.	CIA	Rischio tipico di multitenancy e confini di fiducia sovrapposti.
Containerization attack	Sfrutta la condivisione dell'host OS tra container.	CIA	Se l'host e compromesso, i container possono essere impattati.

4.1 Traffic Eavesdropping

I dati trasferiti verso o dentro il cloud vengono intercettati passivamente. L'attaccante mira a raccogliere informazioni senza modificare il traffico. La proprieta colpita e la confidentiality.

4.2 Malicious Intermediary

L'attaccante si pone tra mittente e destinatario, intercetta messaggi e li modifica prima di inoltrarli. Colpisce confidentiality e integrity.

4.3 Denial of Service e Distributed Denial of Service

Un DoS sovraccarica risorse IT o rete fino a degradare o bloccare il servizio. Un DDoS usa piu sistemi compromessi. La proprieta colpita e la availability.

4.4 Insufficient Authorization e Weak Authentication

L'insufficient authorization concede accessi troppo ampi o errati. La weak authentication deriva da password deboli o account condivisi. Entrambe aumentano il rischio di accessi non autorizzati.

4.5 Virtualization Attack

Sfrutta vulnerabilita della piattaforma di virtualizzazione. Nel cloud e rilevante perche i consumer possono avere accesso amministrativo a risorse virtuali.

4.6 Overlapping Trust Boundaries

In ambienti multi-tenant piu consumer condividono risorse fisiche o logiche. Un consumer malevolo puo colpire risorse condivise e impattare altri consumer.

4.7 Containerization Attack

I container condividono l'host OS. Se l'host viene compromesso, tutti i container su quell'host possono essere impattati. Una mitigazione e isolare container dentro VM, ma aumenta complessita.

5. Malware, botnet e minacce umane

Il malware e un software malevolo progettato per causare danni a sistemi o reti: puo rubare dati, cancellare documenti, ascoltare comunicazioni private o raccogliere informazioni confidenziali.

Tipo	Descrizione	Effetto
Virus	Infetta sistemi e file con codice capace di replicarsi.	Diffusione e danni ai sistemi infetti.
Trojan	Sembra legittimo ma svolge azioni malevole in background.	Backdoor, iniezione di codice, installazione malware.
Spyware	Raccoglie informazioni senza conoscenza dell'utente.	Furto di informazioni.
Adware	Mostra pubblicita indesiderata e puo raccogliere dati.	Rallentamenti e nuove vulnerabilita.
Ransomware	Blocca o cifra dati chiedendo pagamento.	Perdita di accesso ai dati.
Bot	Riceve comandi remoti e comunica con una destinazione esterna.	Partecipazione a botnet.
Rogue antivirus	Finto antivirus che segnala problemi falsi.	Truffa o installazione di malware.
Crypto jacking	Usa risorse per minare criptovaluta senza consenso.	Consumo nascosto di CPU.
Worm	Programma autonomo che si propaga tramite rete.	Diffusione automatica e consumo risorse.

5.1 Botnet

Una botnet usa piu bot distribuiti su host compromessi. Spesso nasce da una infezione malware che crea zombie hosts, poi usati per DDoS, crypto jacking, spam, furto dati o reclutamento di nuovi bot.

5.2 Insider Threat

Una insider threat e una minaccia proveniente da personale interno o soggetti con accesso ai sistemi o ai locali. Puo essere malicious, accidental o negligent.

Tipo di insider threat	Spiegazione	Esempio
Malicious	Danno intenzionale da insider.	Dipendente scontento che ruba dati.
Accidental	Errore non intenzionale.	Cancellazione accidentale di un file.
Negligent	Danno da disattenzione o mancato rispetto policy.	Condivisione incauta di dati riservati.

5.3 Social Engineering e Phishing

Il social engineering manipola le persone inducendole a rivelare informazioni sensibili o compiere azioni dannose. Il phishing e una forma di social engineering basata su comunicazioni elettroniche, come email o messaggi.

6. Attacchi applicativi e avanzati

6.1 Privilege Escalation

L'attaccante compromette un account con pochi privilegi e tenta di ottenere permessi amministrativi sfruttando vulnerabilita o configurazioni errate.

6.2 Brute Force

L'attaccante prova molte combinazioni username/password. Varianti: dictionary attack e credential recycling, cioe riuso di credenziali provenienti da precedenti data breach.

6.3 Remote Code Execution

L'attaccante esegue comandi da remoto su un dispositivo di terzi. Puo abilitare botnet, ransomware e ulteriori compromissioni.

6.4 SQL Injection

L'attaccante inserisce codice SQL malevolo in un campo input. Se l'applicazione non valida l'input, il server puo eseguire quel codice e compromettere database o sistema.

6.5 Tunneling

Dati vengono incapsulati in protocolli autorizzati per bypassare firewall e controlli. E difficile da rilevare perche i pacchetti sembrano rispettare le regole.

6.6 Advanced Persistent Threat

Una APT usa piu attacchi coordinati e persistenti nel tempo. Richiede preparazione e tecnologia sofisticata, percio e tipica contro obiettivi ad alto valore.

7. Confronti rapidi per l'esame

Confronto	Differenza principale	Esempio
Eavesdropping vs malicious intermediary	Il primo ascolta; il secondo modifica.	Copia messaggio vs alterazione messaggio.
DoS vs DDoS	DDoS usa piu sistemi compromessi.	Botnet contro un servizio cloud.
Security breach vs data breach	Accesso non autorizzato vs furto di dati.	Accesso a server vs esfiltrazione database.
Data breach vs data leak	Furto tramite violazione vs esposizione anche accidentale.	Database rubato vs email inviata per errore.
Vulnerability vs exploit	Debolezza vs sfruttamento concreto.	Software non aggiornato vs attacco riuscito.
Authentication vs authorization	Verifica identita vs permessi concessi.	Login vs accesso a database.
Virtualization vs containerization attack	Virtualizzazione/hypervisor vs host OS condiviso.	VM compromessa vs container su stesso host.
Social engineering vs phishing	Categoria generale vs caso via comunicazione elettronica.	Manipolazione telefonica vs email falsa.
APT vs attacco singolo	Persistente, coordinata e multi-attacco.	Campagna lunga contro organizzazione strategica.

Confronto	Differenza principale	Esempio

Schema mentale finale

1) Proteggi i dati: confidentiality e integrity. 2) Proteggi il servizio: availability. 3) Proteggi identita e origine: authenticity. 4) Riduci rischio e vulnerabilita. 5) Limita la superficie d'attacco. 6) Ricorda la responsabilita condivisa nel cloud.

8. Glossario essenziale

Termine	Definizione
Confidentiality	Accesso consentito solo a soggetti autorizzati.
Integrity	Dato non alterato da parti non autorizzate.
Availability	Servizio accessibile e utilizzabile nel periodo previsto.
Authenticity	Origine autorizzata e verificabile.
Non-repudiation	Impossibilita di negare una interazione verificata.
Risk	Possibile perdita indesiderata.
Vulnerability	Debolezza sfruttabile in sistema, policy o processo.
Exploit	Sfruttamento concreto di una vulnerabilita.
Threat agent	Entita capace di realizzare un attacco.
Attack vector	Percorso usato per attaccare.
Attack surface	Insieme dei vettori di attacco disponibili.
Intruder	Attaccante con accesso non autorizzato entro il confine organizzativo.
Botnet	Rete di host compromessi controllati da un attaccante.
APT	Attacco persistente, sofisticato e coordinato nel tempo.

9. Domande d'esame con risposta

Sotto ogni domanda trovi subito la risposta corrispondente. Le domande sono impostate come blocchi per evitare separazioni tra domanda e risposta.

Domanda 1: Che cosa si intende per information security?
Risposta: E l'insieme di tecniche, tecnologie, regolamenti e comportamenti che proteggono integrita e accesso a sistemi informatici e dati. Difende sia da attacchi malevoli sia da errori involontari.

Domanda 2: Che cosa significa confidentiality nel cloud?
Risposta: Significa che dati e risorse sono accessibili solo a parti autorizzate. Nel cloud riguarda soprattutto dati in transito e dati memorizzati.

Domanda 3: Che cosa significa integrity?
Risposta: Significa che il dato non e stato alterato da soggetti non autorizzati. Nel cloud riguarda trasmissione, storage, processing e retrieval dei dati.

Domanda 4: Che cosa significa availability?
Risposta: Significa che un servizio o una risorsa e accessibile e utilizzabile durante uno specifico periodo di tempo.

Domanda 5: Che cosa significa authenticity?
Risposta: Significa che un contenuto o una interazione proviene da una sorgente autorizzata e verificabile. Include il concetto di non-repudiation.

Domanda 6: Qual e la differenza tra security breach e data breach?
Risposta: Una security breach e un incidente che puo portare ad accesso non autorizzato. Una data breach e una security breach in cui vengono rubate informazioni confidenziali.

Domanda 7: Qual e la differenza tra data breach e data leak?
Risposta: Nel data breach c'e furto di dati tramite violazione. Nel data leak informazioni sensibili vengono condivise con soggetti non autorizzati anche senza un attacco, per errore o intenzionalmente.

Domanda 8: Che cosa e una vulnerabilita?
Risposta: E una debolezza fisica, digitale, procedurale o di policy che lascia l'organizzazione esposta a possibili violazioni.

Domanda 9: Che cosa e un exploit?
Risposta: E il momento in cui un attaccante riesce a sfruttare concretamente una vulnerabilita.

Domanda 10: Che cosa e una zero-day vulnerability?
Risposta: E una vulnerabilita di cui l'organizzazione non e ancora consapevole oppure per cui non esiste ancora patch o fix.

Domanda 11: Che differenza c'e tra attack vector e attack surface?
Risposta: L'attack vector e il singolo percorso usato per attaccare. L'attack surface e l'insieme di tutti i vettori disponibili contro un sistema.

Domanda 12: Che cosa e il traffic eavesdropping?
Risposta: E l'intercettazione passiva dei dati trasferiti verso o dentro un cloud. Colpisce soprattutto la confidenzialita e puo rimanere nascosto a lungo.

Domanda 13: Che cosa e un malicious intermediary?
Risposta: E un agente malevolo che intercetta e modifica messaggi, compromettendo confidentiality e/o integrity.

Domanda 14: Qual e l'obiettivo di un attacco DoS?
Risposta: Sovraccaricare risorse IT o rete fino a degradare o bloccare il servizio, compromettendo la availability.

Domanda 15: Che differenza c'e tra DoS e DDoS?
Risposta: Nel DoS l'attacco puo arrivare da una fonte; nel DDoS piu sistemi compromessi inviano traffico verso il bersaglio.

Domanda 16: Che cosa e l'insufficient authorization?
Risposta: E una situazione in cui l'accesso viene concesso erroneamente o in modo troppo ampio, permettendo all'attaccante di raggiungere risorse protette.

Domanda 17: Che cosa e la weak authentication?
Risposta: E una forma debole di controllo dell'identita, ad esempio password deboli o account condivisi, che facilita accessi non autorizzati.

Domanda 18: Che cosa e un virtualization attack?
Risposta: E un attacco che sfrutta vulnerabilita della piattaforma di virtualizzazione per compromettere confidentiality, integrity o availability.

Domanda 19: Perche gli overlapping trust boundaries sono rischiosi?
Risposta: Perche in ambienti cloud condivisi un consumer malevolo puo attaccare risorse condivise e impattare altri consumer nello stesso perimetro di fiducia.

Domanda 20: Perche i container sono esposti a containerization attack?
Risposta: Perche container diversi sullo stesso host condividono lo stesso sistema operativo host; se l'host viene compromesso, anche i container possono essere impattati.

Domanda 21: Che cosa e il malware?
Risposta: E software malevolo progettato per danneggiare sistemi o reti, rubare dati, cancellare documenti, ascoltare comunicazioni o raccogliere informazioni.

Domanda 22: Che cosa e una botnet?
Risposta: E una rete coordinata di bot distribuiti su host compromessi, usata per DDoS, crypto jacking, spam, furto dati o reclutamento di nuovi bot.

Domanda 23: Che cosa e una insider threat?
Risposta: E una minaccia proveniente da personale o soggetti interni con accesso a sistemi o locali aziendali. Puo essere malevola, accidentale o negligente.

Domanda 24: Che differenza c'e tra social engineering e phishing?
Risposta: Il social engineering e la manipolazione delle persone per ottenere informazioni o azioni dannose. Il phishing e una forma di social engineering tramite comunicazione elettronica.

Domanda 25: Che cosa e la privilege escalation?
Risposta: E un attacco in cui, dopo aver compromesso un account con pochi privilegi, l'attaccante tenta di ottenere permessi amministrativi.

Domanda 26: Che cosa e un brute force attack?
Risposta: E un attacco che prova molte combinazioni di username e password. Varianti: dictionary attack e credential recycling.

Domanda 27: Che cosa e la remote code execution?
Risposta: E un attacco che permette di eseguire comandi da remoto su un dispositivo di terzi; puo abilitare botnet, ransomware e altre compromissioni.

Domanda 28: Che cosa e la SQL injection?
Risposta: E l'inserimento di codice SQL malevolo in un campo di input di una web application, portando il server a eseguire codice non autorizzato.

Domanda 29: Che cosa e il tunneling?
Risposta: E l'incapsulamento di dati dentro protocolli autorizzati per bypassare firewall e controlli, rendendo difficile il rilevamento.

Domanda 30: Che cosa e una APT?
Risposta: E una campagna di attacco sofisticata, coordinata e persistente, composta da piu attacchi nel tempo contro obiettivi ad alto valore.

10. Ripasso ultrarapido

- CIA = Confidentiality, Integrity, Availability.
- Authenticity = origine autorizzata e verificabile; include non-repudiation.
- Rischio != vulnerabilita: il rischio e la possibile perdita, la vulnerabilita e la debolezza che puo causarla.
- Exploit = sfruttamento concreto di una vulnerabilita.
- Eavesdropping ascolta; malicious intermediary modifica.
- DoS/DDoS colpiscono availability.
- Weak authentication riguarda identita; insufficient authorization riguarda permessi.
- Virtualization attack e containerization attack sono importanti perche il cloud usa ambienti virtualizzati e condivisi.
- Social engineering sfrutta le persone; phishing e la versione via comunicazione elettronica.
- APT = attacco avanzato, persistente e coordinato nel tempo.